



Instituto Politécnico Nacional

Escuela Superior de Cómputo

IT Governance

Cedula de Servicio

Equipo:

Estrada Chávez Dilan Daniel

Horteales Morales Antony

Rojo Ibarra Jesús

7CV4

Fecha de entrega: 6 de mayo de 2026

	INSTITUTO POLITÉCNICO NACIONAL ESCUELA SUPERIOR DE CÓMPUTO	HOJA	2 DE 11
		ID DEL SERVICIO	06500
		FECHA DE ELABORACIÓN	27/04/2026
	CEDULA DE SERVICIO		

Información general del servicio de IT

Nombre de la Empresa:	SecCompany
Departamento:	Cómputo

Nombre del servicio	Correo electrónico			
Tipo de servicio	Nuevo: ☒	Cambio : ☐	Retiro : ☐	Activo : ☐
Listado de la(s) variante(s) o sub-servicio(s)	1. Evaluación de Vulnerabilidades 2. Pruebas de Penetración Web (Web Pentesting) 3. Simulación de Ingeniería Social (Phishing)			
Descripción del servicio	Servicio de seguridad ofensiva que evalúa la postura de ciberseguridad de las organizaciones mediante la simulación controlada de técnicas y tácticas utilizadas por atacantes reales. Emplea metodologías reconocidas internacionalmente (OWASP, NIST, MITRE ATT&CK) e incluye evaluación de vulnerabilidades, pruebas de penetración a aplicaciones web e ingeniería social.			
Alcance	Organizaciones con oficinas en Ciudad de México que gestionen datos sensibles, transacciones financieras o propiedad intelectual: Sector Financiero, Comercio Electrónico / Retail (PCI-DSS) y Sector Salud. Tecnico: Servidores, redes, bases de datos, aplicaciones web y portales transaccionales			

Objetivo del servicio	Evaluar integralmente la postura de ciberseguridad de las organizaciones cliente mediante la ejecución controlada de análisis de vulnerabilidades, pruebas de penetración y simulaciones de ataques reales, con el propósito de mitigar riesgos
-----------------------	---

	INSTITUTO POLITÉCNICO NACIONAL ESCUELA SUPERIOR DE CÓMPUTO	HOJA	3 DE 11
		ID DEL SERVICIO	06500
		FECHA DE ELABORACIÓN	27/04/2026
		CEDULA DE SERVICIO	

	tecnológicos, asegurar el cumplimiento normativo y proporcionar a la alta dirección información clave para la toma de decisiones estratégicas orientadas a proteger el valor del negocio.
Usuarios a quienes se brinda el servicio	Alta Dirección / CISO / Gerencia de TI de organizaciones cliente
Beneficios del servicio	1. Gestión de riesgos – Visibilidad cuantificable del riesgo tecnológico mediante evidencia empírica de vulnerabilidades reales, facilitando la priorización objetiva de mitigaciones críticas. 2. Entrega de valor – Optimización y justificación del presupuesto de ciberseguridad (ROI): datos concretos de qué controles funcionan y cuáles fallan, evitando gasto redundante. 3. Compliance – Aseguramiento del cumplimiento normativo (ISO 27001, PCI-DSS, regulaciones financieras) y protección reputacional ante auditores, reguladores y socios comerciales.
Demanda del servicio	Frecuencia estimada: Por proyecto (transaccional) con posibilidad de evaluaciones periódicas anuales Duración promedio: 4 meses por proyecto Disparador de solicitud: Auditoría de cumplimiento normativo, expansión digital, detección de incidentes previos o política interna

Responsables del servicio (Matriz RACI)

Actividad/ROL	Líder de Proyecto	Analista de Vulnerabilidades	Pentester
Planeación y Alcance (ROE)	R / A	I	C
Reconocimiento (OSINT)	A	R	C
Evaluación de Vulnerabilidades	A	R	R
Pentesting (Web e Infraestructura)	A	C	R
Ingeniería Social	R	C	R
Análisis de Resultados	R	R	R
Reporte y Cierre	R / A	C	C

	INSTITUTO POLITÉCNICO NACIONAL ESCUELA SUPERIOR DE CÓMPUTO	HOJA	4 DE 11
		ID DEL SERVICIO	06500
		FECHA DE ELABORACIÓN	27/04/2026
		CEDULA DE SERVICIO	

Rol	Nombre	Correo electrónico	Teléfono/ extensión	Horario de atención
Líder de Proyecto y Gobierno de Seguridad	Rojo Ibarra Jesús	jesds3us@gmail.com	5512341234	10:00 – 16:00
Ingeniero de Seguridad Ofensiva (Pentester)	Dilan Daniel Estrada Chávez	Destrada@hotmail.com	7731958732	09:00 – 17:00
Analista de Vulnerabilidades	Horteales Morales Antony	Horteales.morales.antony@gmail.com	5512345678	09:00 – 17:00

Condiciones generales o requisitos para proporcionar el servicio

Para la correcta, legal y segura ejecución del Servicio de Seguridad Ofensiva, el Cliente y el Prestador del servicio acuerdan cumplir con las siguientes condiciones y requisitos:

3.1. Requisitos previos del Cliente

El Cliente deberá garantizar lo siguiente antes del inicio de la fase de Planeación (RoE):

1. Designación de Contraparte Técnica: El Cliente deberá nombrar formalmente a un representante técnico (punto de contacto) con autoridad para tomar decisiones operativas durante el proyecto.
2. Acceso a Activos y Autorizaciones: El Cliente deberá proporcionar un listado actualizado de direcciones IP, rangos de red, URLs, aplicaciones específicas y usuarios de prueba que serán incluidos en el alcance autorizado.
3. Ambientes de Pruebas: Para pruebas destructivas o de alta criticidad, se deberá proporcionar un ambiente de pruebas/certificación (no productivo) cuando sea posible. Si las pruebas deben realizarse en producción, el Cliente acepta por escrito el riesgo de interrupción del servicio (ver sección 3.4).
4. Cuentas y Credenciales: Para la simulación de ingeniería social, el Cliente deberá proporcionar un listado de correos corporativos autorizados (dominio completo). Para pruebas de penetración en caja blanca/gris, se proporcionarán credenciales con privilegios básicos.

	INSTITUTO POLITÉCNICO NACIONAL ESCUELA SUPERIOR DE CÓMPUTO	HOJA	5 DE 11
		ID DEL SERVICIO	06500
		FECHA DE ELABORACIÓN	27/04/2026
	CEDULA DE SERVICIO		

3.2. Requisitos Legales y de Cumplimiento (Permisos)

El servicio solo se iniciará una vez que se hayan firmado los siguientes documentos:

1. Contrato de Confidencialidad (NDA): El prestador del servicio se obliga a no divulgar la información del Cliente. El Cliente se obliga a no divulgar las metodologías y herramientas del prestador.
2. Reglas de Compromiso (RoE - Rules of Engagement): Documento legal que define explícitamente:
 - a. Qué se puede hacer: Técnicas permitidas (OWASP, MITRE ATT&CK).
 - b. Qué NO se puede hacer: Prohibición expresa de ataques a terceros, modificación de datos sin respaldo, denegación de servicio intencionada.
 - c. Ventanas de tiempo: Franjas horarias autorizadas para pruebas activas (ej. solo de 22:00 a 06:00).
3. Carta de Autorización (Permiso de Pruebas): Documento firmado por la alta dirección del Cliente autorizando al equipo ofensivo a intentar vulnerar los activos especificados en el alcance, eximiendo de responsabilidad penal al prestador por actos cometidos dentro del RoE.

3.3. Condiciones de Ejecución y Manejo de Incidentes

1. Manejo de Hallazgos Accidentalmente Críticos: Si durante la prueba se descubre una vulnerabilidad que podría comprometer la integridad de un empleado o un riesgo de seguridad nacional, la prueba se detendrá inmediatamente y se notificará al punto de contacto en un plazo no mayor a 2 horas.
2. Manejo de Datos Sensibles: El equipo evaluador no descargará, copiará ni almacenará bases de datos completas. Solo se extraerán "Pruebas de Concepto (PoC)" mínimas y anonimizadas (ej. un solo registro de prueba). Si se accede a datos reales sensibles, la evaluación se pausa y se notifica al Cliente.
3. Cese de Actividades: El Cliente tiene el derecho de solicitar la detención inmediata del servicio en cualquier momento. El prestador está obligado a detener todas las actividades de explotación en un plazo máximo de 30 minutos.

3.4. Aceptación de Riesgos Residuales por parte del Cliente

El Cliente acepta y entiende los siguientes riesgos documentados en el caso de negocio:

	INSTITUTO POLITÉCNICO NACIONAL ESCUELA SUPERIOR DE CÓMPUTO	HOJA	6 DE 11
		ID DEL SERVICIO	06500
		FECHA DE ELABORACIÓN	27/04/2026
		CEDULA DE SERVICIO	

1. Riesgo Operativo (Interrupción): Existe una probabilidad baja (pero no nula) de que las pruebas de penetración o escaneos automáticos causen una caída temporal (DoS no intencionado) de servicios críticos. El Cliente acepta este riesgo y se recomienda tener respaldos recientes.
2. Riesgo de Ejecución Fuera de Alcance: El prestador no será responsable si, actuando dentro de la diligencia debida, compromete accidentalmente infraestructura de un tercero si el Cliente no especificó correctamente su propiedad (ej. IPs compartidas en la nube).
3. Riesgo de Falsa Sensación de Seguridad: El Cliente reconoce que aprobar un pentest sobre una aplicación específica NO certifica la seguridad de toda la organización. El servicio provee una foto del estado actual en el momento de la prueba, no una garantía futura.

3.5. Obligaciones del Prestador del Servicio

1. Personal Calificado: Todo el personal técnico (Pentester, Analista) deberá estar certificado en metodologías éticas (ej. OSCP, CEH, o equivalentes) y haber firmado un código de conducta interno.
2. Infraestructura Aislada: Las pruebas se realizarán desde infraestructura de red aislada (VPS dedicados) y herramientas debidamente segmentadas del resto de operaciones del prestador.
3. Entrega Segura de Resultados: Los reportes técnicos y ejecutivos (hallazgos, PoCs, vulnerabilidades) deberán entregarse cifrados (AES-256) y transmitirse por canales seguros (no correo electrónico plano). El prestador eliminará toda copia de datos del Cliente 30 días después de la presentación del informe final, salvo obligación legal en contrario.

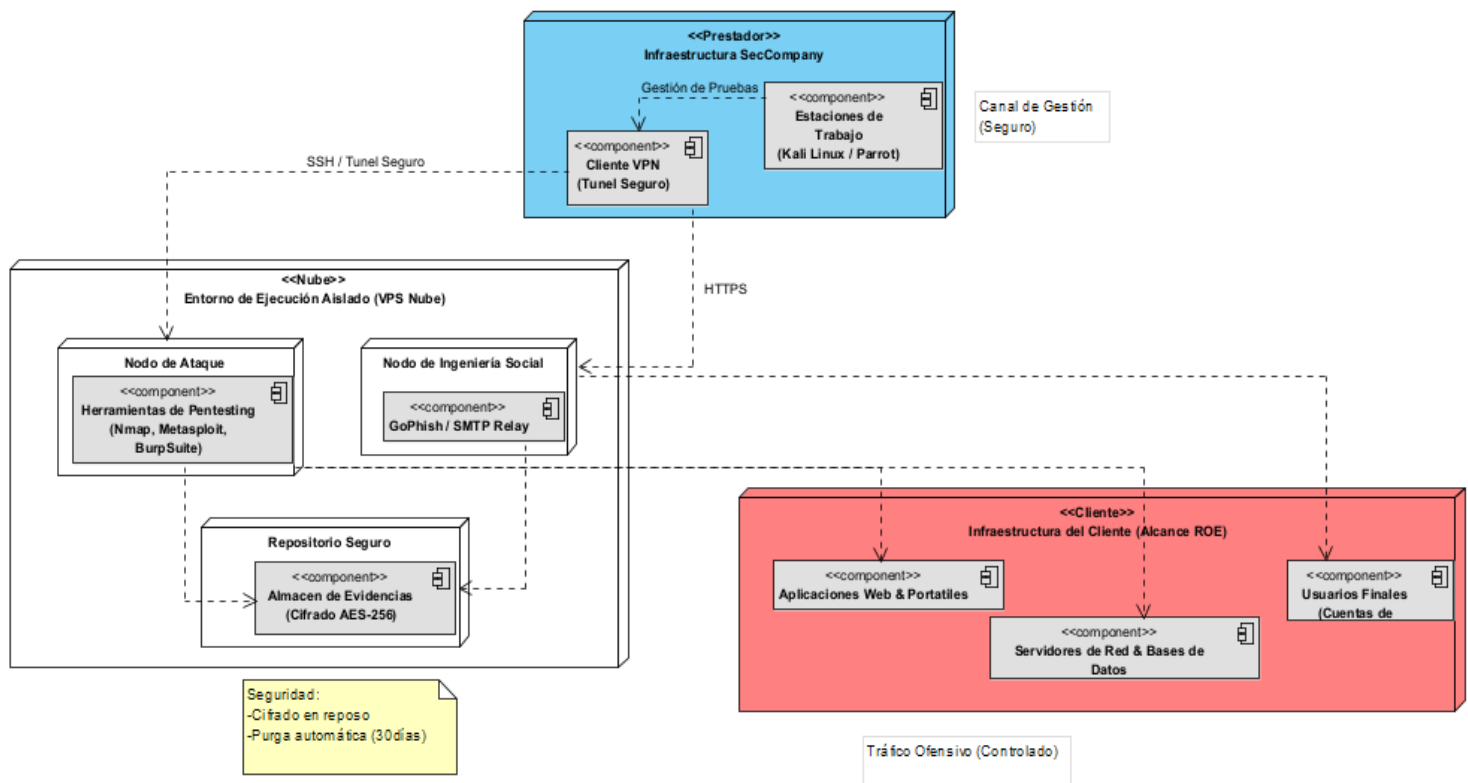


INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

CEDULA DE SERVICIO

HOJA	7 DE 11
ID DEL SERVICIO	06500
FECHA DE ELABORACIÓN	27/04/2026

Identificación de componentes de infraestructura



Niveles de servicio (SLA-acuerdos de servicios para los usuarios)

Tipo de nivel de servicio	Compromiso del nivel de servicio
Disponibilidad y tiempos de respuesta	
Disponibilidad	El servicio estará disponible para atención de solicitudes y consultas 24 horas del día, los 365 días del año a través del correo institucional del equipo. La ejecución técnica de las pruebas se programa dentro de ventanas acordadas con el cliente. Las pruebas activas (escaneos, explotación) se ejecutan preferentemente en horario no crítico del cliente para evitar impacto operativo.



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

HOJA	8 DE 11
ID DEL SERVICIO	06500
FECHA DE ELABORACIÓN	27/04/2026

CEDULA DE SERVICIO

Tiempo de respuesta a solicitudes	- Solicitud inicial Respuesta en máximo 48 horas hábiles tras recibir la solicitud de servicio. - Kick-off Sesión de inicio programada dentro de los 5 días hábiles siguientes a la firma del NDA y RoE. - Incidente durante pruebas Notificación al cliente en máximo 2 horas ante cualquier hallazgo crítico o interrupción no intencionada.
Soporte vía remota y presencial:	- Remoto Atención vía correo electrónico y videollamada de lunes a viernes de 9:00 a 18:00 hrs. Tiempo de respuesta máximo: 4 horas hábiles. - Presencial Disponible para reunión de kick-off, ejecución de pruebas on-site y presentación ejecutiva de resultados, previa coordinación con al menos 3 días hábiles de anticipación. - Urgente Ante hallazgo crítico activo, el equipo ofrece atención de emergencia dentro de las 2 horas siguientes a la notificación.
Entrega de resultados	El reporte técnico y ejecutivo final será entregado en un plazo máximo de 10 días hábiles tras la finalización de la fase de pruebas. El plan de remediación se entrega de forma simultánea al reporte (en paralelo, conforme al proceso 3). El certificado de debida diligencia se emite dentro de los 5 días hábiles posteriores a la presentación ejecutiva aprobada.
Confidencialidad y manejo de información	
Confidencialidad	Todo hallazgo, dato, credencial o información extraída durante las pruebas será tratado con carácter estrictamente confidencial y estará sujeto al Acuerdo de No Divulgación (NDA) firmado en la fase de inicio. Los reportes generados se entregarán únicamente al contacto autorizado designado por la organización cliente. La información no será compartida con terceros bajo ninguna circunstancia, salvo requerimiento legal explícito y notificado al cliente. El equipo se compromete a destruir o devolver toda evidencia técnica (capturas, logs, credenciales) al cierre formal del servicio, conforme a lo pactado en el RoE.
Retención y destrucción de datos	Los datos sensibles obtenidos durante la ejecución serán eliminados de forma segura (borrado certificado) dentro de los 5 días hábiles posteriores al cierre del servicio. Se entregará constancia de destrucción al cliente si se solicita.



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

HOJA	9 DE 11
ID DEL SERVICIO	06500
FECHA DE ELABORACIÓN	27/04/2026

CEDULA DE SERVICIO

Seguridad y control de las pruebas

Seguridad	Todas las pruebas se ejecutarán exclusivamente dentro del alcance definido en el documento RoE firmado. Ninguna acción técnica se realizará sobre activos, IPs o sistemas no autorizados. El equipo implementará medidas de control activo para evitar impactos no intencionados (DoS, pérdida de datos, interrupción de servicios productivos). Las técnicas empleadas seguirán marcos reconocidos internacionalmente: OWASP Top 10 MITRE ATT&CK NIST.
Control de alcance y cambios	Cualquier modificación al alcance técnico durante la ejecución del servicio requerirá la firma de una adenda al RoE vigente y aprobación del Líder de Proyecto antes de proceder. No se realizarán acciones fuera del alcance bajo ninguna circunstancia, incluso si se descubren vulnerabilidades adyacentes.
Gestión de hallazgos críticos	Si durante las pruebas se detecta una vulnerabilidad de severidad Crítica (CVSS ≥ 9.0), el equipo notificará al cliente en un plazo máximo de 2 horas para coordinar acciones inmediatas, incluso si las pruebas se encuentran en fase activa.

Calidad y cumplimiento normativo

Calidad del servicio	Los reportes entregados incluirán: clasificación de vulnerabilidades por severidad (CVSS), evidencia técnica reproducible (PoC), impacto estimado al negocio y recomendaciones de remediación priorizadas. El cliente podrá solicitar una revisión del reporte sin costo adicional dentro de los 5 días hábiles siguientes a su recepción.
Cumplimiento normativo	El servicio se ejecuta alineado a estándares que facilitan el cumplimiento de: ISO 27001 PCI-DSS NIST CSF. Al término, se emite un Certificado de Debida Diligencia que el cliente puede presentar ante auditores y reguladores como evidencia de evaluación de seguridad.
Satisfacción del cliente	Al cierre de cada proyecto se aplicará una encuesta de satisfacción para medir la calidad del servicio. El equipo se compromete a atender retroalimentación formal dentro de los 3 días hábiles posteriores a su recepción.



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

HOJA	10 DE 11
ID DEL SERVICIO	06500
FECHA DE ELABORACIÓN	27/04/2026

CEDULA DE SERVICIO

Niveles de servicio (OLA-acuerdos de servicios respecto a elementos de configuración de infraestructura, aplicaciones, etc.)

Elementos de configuración	Tipo de nivel de servicio y compromiso del nivel de servicio	Métricas de los niveles de servicio
APLICACIONES (herramientas de pentest: escáneres de vulnerabilidades, frameworks de explotación, proxies, etc.)	Capacidad: Las herramientas deberán soportar escaneos simultáneos a hasta 5,000 activos por proyecto sin degradación.	
	Disponibilidad: 99.5% durante ventanas de prueba autorizadas.	
	Seguridad: Todo tráfico generado desde infraestructura aislada (VPS dedicados). Herramientas actualizadas a última versión estable.	
	Respaldos: Configuraciones y scripts personalizados respaldados diariamente.	
	Mantenimiento: Actualización semanal de firmas de vulnerabilidades y bases de datos CVE.	
	Mantenibilidad: Personal certificado (OSCP, CEH) con capacidad de modificar scripts en ≤ 4 horas.	
	Mantenibilidad: Personal certificado (OSCP, CEH) con capacidad de modificar scripts en ≤ 4 horas.	
Niveles de servicio para software/aplicación (bases de datos, plataformas, sistemas, etc.):		
INFRAESTRUCTURA (VPS, servidores de reporte, almacenamiento cifrado, VPN)	Capacidad: Ancho de banda mínimo 1 Gbps para pruebas. Almacenamiento cifrado mínimo 500 GB para logs y evidencias.	
	Disponibilidad: 99.9% para plataforma de entrega de reportes.	
	Seguridad: Comunicación cifrada (TLS 1.3) entre nodos de prueba. Autenticación MFA para acceso a consolas.	



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

HOJA	11 DE 11
ID DEL SERVICIO	06500
FECHA DE ELABORACIÓN	27/04/2026

CEDULA DE SERVICIO

	Respaldos: Respaldos incrementales diarios de configuraciones de red y reglas de firewall.		
	Mantenimiento: Parches de seguridad aplicados en ≤ 48 hrs.		
	Mantenibilidad: Tiempo de restauración de servicio ≤ 4 hrs ante falla crítica.		